

Plantilla de Reporte Ejecutivo STRIDE (para presentación tipo PowerPoint)

Estructura sugerida de un reporte ejecutivo basado en los resultados de la Encuesta STRIDE, pensado para comités de dirección, consejos de administración y otras criaturas decididamente humanas.

Portada

- Título:
“Informe de Madurez STRIDE de Ciberseguridad – [Nombre de la organización] – [Año]”
- Subtítulo:
“Spoofing, Tampering, Repudiation, Divulgación, DoS y Privilegios: un viaje guiado”.
- Datos: fecha, responsables, área promotora (CISO / Riesgos / Auditoría).

Diapositiva 1 – Resumen ejecutivo

Contenido sugerido:

- 3–4 bullets sobre:
- Nivel global de madurez (IGM-STRIDE).
- Principales fortalezas (categorías con mejor puntuación).
- Principales debilidades (brechas relevantes).
- Riesgos normativos / operativos asociados.
- Un gráfico sencillo (barra o velocímetro) con el IGM-STRIDE sobre la escala 0–1 y calificación cualitativa (Inicial, Básico, Intermedio, Avanzado).

Diapositiva 2 – Metodología

- Breve explicación de la encuesta:
- Número de preguntas y bloques.
- Roles participantes.
- Fecha de realización y alcance (organización completa, unidad, servicio crítico).
- Referencia a NIS2, ENS y otros marcos relevantes como guías de fondo.

Diapositiva 3 – Perfil STRIDE

- Gráfico radar (o barras apiladas) con las puntuaciones normalizadas de:
- S (Spoofing)
- T (Tampering)
- R (Repudiation)
- I (Information Disclosure)
- D (Denial of Service)
- E (Elevation of Privilege)
- GOV (Gobierno)
-
- MET (Métricas)
-
- Comentario breve por categoría (1 frase por letra) resaltando el nivel y una idea clave.

MET (Métricas)

Comentario breve por categoría (1 frase por letra) resaltando el nivel y una idea clave.

Diapositiva 4 – Spoofing e identidad

- Subtítulo: “Quién dice ser quién”
- Elementos:
- Puntuación de Spoofing.
- 2–3 indicadores clave (por ejemplo:
 - % de accesos críticos con MFA.
 - Estado de la gestión de identidades privilegiadas.
 - Cobertura de autenticación fuerte en APIs).
- 1–2 riesgos destacados y 1–2 acciones prioritarias.
- % de accesos críticos con MFA.
- Estado de la gestión de identidades privilegiadas.
- Cobertura de autenticación fuerte en APIs).

Diapositiva 5 – Tampering e integridad

- Subtítulo: “Lo que se escribe no se borra (o sí)”
- Elementos:
- Puntuación de Tampering.
- Indicadores representativos:
 - % de datos/logs críticos con integridad criptográfica.
 - Gestión de cambios.
 - Riesgos en IoT/OT, si aplica.
- Próximos pasos propuestos (controles técnicos y organizativos).
- % de datos/logs críticos con integridad criptográfica.
- Gestión de cambios.
- Riesgos en IoT/OT, si aplica.

Diapositiva 6 – Repudiation y trazabilidad

- Subtítulo: “Quién hizo qué, cuándo y cómo lo explicamos”
- Contenido:
- Puntuación de Repudiation.
- Nivel de cobertura de logging e inmutabilidad.
- Capacidad para reconstruir incidentes (ejercicios realizados).
- Implicaciones legales/normativas (NIS2, ENS, auditoría).

Diapositiva 7 – Information Disclosure y confidencialidad

- Subtítulo: “Lo que no debe saberse (ni filtrarse)”
- Contenido:
- Puntuación de Information Disclosure.
- Estado de clasificación de datos y cifrado.
- Riesgos en integraciones con terceros y cloud.
- Consideraciones sobre IA y fuga de datos.

Diapositiva 8 – DoS y resiliencia

- Subtítulo: “Cuando lo importante es seguir funcionando”
- Contenido:
- Puntuación de Denial of Service.
- Indicadores de disponibilidad y pruebas de continuidad.
- Preparación frente a ataques de saturación.
- Resiliencia del propio SOC / capacidades de seguridad.

Diapositiva 9 – Elevation of Privilege

- Subtítulo: “Pequeños golpes de Estado digitales”
- Contenido:
- Puntuación de Elevation of Privilege.
- Estado de PAM, mínimo privilegio y segregación de funciones.
- Riesgos concretos identificados (ejemplos sin detalles sensibles).
- Acciones estratégicas de reforzamiento.

Diapositiva 10 – Métricas y ROI

- Subtítulo: “De la fe a los datos”
- Contenido:
- Visión de conjunto del cuadro de mando existente.
- 3–5 controles con mejor ROI estimado (ejemplo: MFA, PAM, WAF, logging centralizado).
- Propuesta de evolución del sistema de métricas a 12–24 meses.

Diapositiva 11 – Roadmap de mejora

- Tabla o diagrama con:
- 5–10 acciones priorizadas.
- Plazo (corto, medio, largo).
- Responsable (área).
- Relación con categorías STRIDE y requisitos normativos.

Diapositiva 12 – Cierre y próximos pasos

- Recordatorio:
- Periodicidad recomendada de repetir la encuesta.
- Necesidad de alinear resultados con presupuestos y planificación.
- Propuesta de seguimiento (comité trimestral, indicadores, etc.).
- Espacio para preguntas y comentarios.